

HTCS6704 Cybersecurity Management

Assignment 2: Risk Assessment

By Young Kwang Kweon (1605812)

Executive Summary

This report provides a detailed application of integrating NIST CSF 2.0 with CareConnect's security policy for 'GetWellSoon', a newly established pharmacy in New Zealand, which has six key functions: '**Govern**', '**Identify**', '**Protect**', '**Detect**', '**Respond**', and '**Recover**'.

The objective is to assess potential cybersecurity risks such as '**Inaccessible Sensitive Data from Encryption**' and '**Unauthorised Access to the Pharmacy's Patient Health Records**' that could arise from two of the possible threats: '**Ransomware Attack**' and '**Insider negligence**'; and two exploitable vulnerabilities: '**Outdated Software**' and '**Weak Passwords**'.

To mitigate these risks, recommendations include '**Strengthen Backup and Recovery Controls**' by regularly backing up data in cloud service and testing data restoration monthly, and '**Enhance Staff Training and Access Control Policies**' by conducting quarterly staff training and enforcing a password expiry cycle of 90 days, prohibiting shared user accounts, and end user access immediately when a staff member leaves employment.

By adopting the NIST CSF 2.0 to manage risks, GetWellSoon will enhance its cybersecurity resilience and ensure the secure management of patient information.

Table of Contents

Executive Summary	2
Introduction	4
Cybersecurity Framework	5
Choosing a Framework	5
Application of the Framework	6
Govern	7
Identify	7
Protect	8
Detect	8
Respond	9
Recover	9
Statement of Sensitivity	9
Effects of Using the CareConnect Policy	11
Threats	11
Vulnerabilities	12
Security Breaches	13
Recommendations	14
Conclusion	15
References	16
Appendices	18

Introduction

CareConnect Group, an initiative by the four Northern Region DHBs, has given a security policy for 'GetWellSoon', a newly established pharmacy, to adapt. The CEO of GetWellSoon has approached me for assistance. As a cybersecurity expert, my task is to help them identify and apply an appropriate cybersecurity framework, as well as manage associated risks.

The purpose of this report is to assess cybersecurity risks for GetWellSoon, evaluate the impact of adopting the CareConnect Security Policy on the pharmacy's operations, and recommend improvements to the policy for enhancing the pharmacy's security governance.

This report covers why the NIST Cybersecurity Framework (NIST CSF) 2.0 is appropriate for the pharmacy and how it can be applied to GetWellSoon's operations. It also examines the effects of using TestSafe on the pharmacy information system operations and its stakeholders, as well as governance recommendations for secure integration with TestSafe.

This report will assist GetWellSoon in achieving the goal of preserving critical data securely and continuous business operations while complying with CareConnect's security policy.

Cybersecurity Framework

Choosing a Framework

As a pharmacy, GetWellSoon has the responsibility of protecting patients' health records from data breaches. To do so, applying an appropriate cybersecurity framework that aligns well with their operation is necessary. When choosing the proper framework, there are factors that need to be considered:

- Type of business
- Size of business
- Regulatory and Legal compliance of the country in which the business is operating
- What the business wants to protect
- Resource and Budget

GetWellSoon is a recently established pharmacy in New Zealand, which means it can be categorised as a healthcare business. As a recently established business, it is a small to medium-sized pharmacy with limited resources and a budget. As it operates in New Zealand, they also need to comply with New Zealand Privacy laws. Based on GetWellSoon's business requirements, the **NIST Cybersecurity Framework (NIST CSF) 2.0** is the ideal framework for the pharmacy.

NIST CSF 2.0 is the latest guideline developed by NIST, providing comprehensive guidance and best practices that private sector organisations can follow to improve information security and manage and reduce cybersecurity risks ("What is the NIST Cybersecurity Framework?", *n.d.*).

It is well-suited to small organisations like GetWellSoon, focuses on identifying and prioritising critical assets and risks which are vital for protecting health data and managing limited pharmacy resources effectively, complements New Zealand's Health Information Privacy Code (1994), Privacy Act (2020), New Zealand Health Network Code of Practice, and of course, CareConnect's security policy. It is also open source, so it does not require certification fees or consultants to get started using it.

Application of the Framework

Under NIST CSF 2.0, there are six functions: **govern, identify, protect, detect, respond,** and **recover** (Raimondo & Locascio, 2024). Refer to Appendix A. Each Function can be

broken down into smaller categories and subcategories, clearly defining detailed outcomes for cybersecurity tasks and processes as follows:

Function	Category	Category Identifier
<u>Govern (GV)</u>	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Roles, Responsibilities, and Authorities	GV.RR
	Policy	GV.PO
	Oversight	GV.OV
	Cybersecurity Supply Chain Risk Management	GV.SC
<u>Identify (ID)</u>	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
<u>Protect (PR)</u>	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
<u>Detect (DE)</u>	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
<u>Respond (RS)</u>	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
<u>Recover (RC)</u>	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO

Figure 1. Functions of NIST CSF 2.0. From *How to Implement NIST CSF 2.0*, by SaltyCloud Research Team, 2025, saltycloud (<https://www.saltycloud.com/blog/how-to-implement-nist-csf/>)

1. Govern

The initial step in implementing NIST CSF 2.0 is ‘**Govern**’. It ensures that cybersecurity efforts are aligned with business objectives and risk management strategies (Kariwala, 2025). It can be broken down into six subcategories:

- **Organisational Context:** Define GetWellSoon's security goal, which is to protect patient health information shared via TestSafe while complying with CareConnect's proposed security policy.
- **Risk Management Strategy:** Define risk tolerance, policies, and decision-making processes. The owner must define how much risk Getwellsoon is willing to accept. Define things such as acceptable levels of downtime (e.g., maximum hours for TestSafe outage).
- **Roles, Responsibilities, and Authorities:** Assign security leads and define clear responsibilities and accountability for security tasks for all staff. Leaders in GetWellSoon could be the owner, manager, or any senior staff member.
- **Policy:** Adapt CareConnect's security policy, and ensure the pharmacy covers all 11 required areas.
- **Oversight:** Monitor the number of security incidents, evaluate cybersecurity effectiveness by periodically reviewing security policy, and continuously improve by conducting regular review meetings with security partners.
- **Cybersecurity Supply Chain Risk Management:** Managing Third-Party Cybersecurity Risks. Suppliers could include software vendors, cloud backup providers, and TestSafe gateway suppliers. Ensure contracts include data-protection clauses compliant with the NZ Health Network Code of Practice (2023).

2. Identify

The second step is '**Identify**'. It focuses on understanding and managing an organisation's assets and the criticality of cybersecurity risks. It can be broken down into three subcategories:

- **Asset Management:** Identify and catalogue all the assets that GetWellSoon needs to protect.
- **Risk Assessment:** Conduct risk assessments every two years, as recommended in **Section 3.5** of the CareConnect policy, to identify threats and vulnerabilities. Risks can be prioritised by likelihood and impact. Refer to Appendix B.
- **Improvement:** Enhance cybersecurity processes by regularly identifying areas for improvement based on lessons learned and continuously refining them.

3. Protect

The third step is '**Protect**'. It ensures that safeguards are in place to protect assets from cybersecurity incidents and reduce the likelihood of data breaches. It can be broken down into five subcategories:

- **Identity Management, Authentication, and Access Control:** Apply access controls to enforce unique user IDs, role-based access, and password policies consistent with **Section 7** of the CareConnect policy. Implement MFA for TestSafe access.
- **Awareness and Training:** Deliver security training for all staff. Ensure staff sign confidentiality agreements as mentioned in **Section 5.3** of the CareConnect policy.
- **Data Security:** Encrypt all patient health records and financial data and disable USB ports to align with policy **section 3.4**.
- **Platform Security:** Secure applications and operating systems by conducting quarterly antivirus and vulnerability scans using automated tools. Ensure that you maintain patch management schedules as specified in **Section 9.2** of the security policy document.
- **Technology:** Ensure infrastructures can withstand and recover from power outages or cyberattacks by regularly backing up data in local and cloud servers. This allows for continuity of operation.

4. Detect

The fourth step is '**Detect**'. This step involves continuous monitoring of cybersecurity threats and identifying vulnerabilities before they can cause harm. Early detection helps organisations respond to incidents effectively and prevent damage. It can be broken down into two subcategories:

- **Continuous Monitoring:** Implement automated logging and intrusion detection tools to monitor unusual network traffic and user behaviour to comply with **Section 10.4** of the security policy.
- **Adverse Event Analysis:** Schedule monthly audit logs for reviews and identify any potential security incidents.

5. Respond

The fifth step is '**Respond**'. It focuses on handling cybersecurity incidents once they are detected. It can be broken down into four subcategories:

- **Incident Management:** Develop an Incident Response Plan (IRP) aligned with **section 10.2** of CareConnect's policy.
- **Incident Analysis:** Investigate incidents to understand their impact.
- **Incident Response Reporting and Communication:** Report incidents to the cyberteam and inform stakeholders about the incidents.
- **Incident Mitigation:** Implement corrective controls to reduce the incident's negative effects.

6. Recover

The last step is '**Recover**'. It ensures organisations' operations can continue after cybersecurity incidents. It can be broken down into two subcategories:

- **Incident Recovery Plan Execution:** Restore systems and services affected by the incident to resume operations promptly.
- **Incident Recovery Communication:** Update stakeholders, customers, and regulators on the progress of recovery activities.

Statement of Sensitivity

A Statement of Sensitivity (SoS) is a concise section, often part of a cybersecurity plan, that defines the sensitivity of an organisation's information and systems and the potential harm that would occur if the data were disclosed, altered, or destroyed. GetWellSoon needs to create a SoS that documents the confidentiality, integrity, and availability requirements of an information system, as well as identify the Information Classification (Ministry of SaskBuilds and Procurement, 2024). Here is an example of SoS for GetWellSoon:

Asset Category	Example Assets	Confidentiality Impact	Integrity Impact	Availability Impact	Overall Sensitivity	Owner / Custodian
Patient Health Information	TestSafe records, prescriptions, allergies, lab results	Very High	High	High	High	Pharmacy Security Officer
Dispensing System Data	Pharmacy management software database (e.g., RxOne or Tonic)	High	High	High	High	Pharmacist / PSO
Customer Contact and Payment Data	Names, phone numbers, EFTPOS details	High	Medium	Medium	High	Pharmacy Manager
Staff Records and Payroll Data	Employment files, rosters, pay slips	Medium	Medium	Medium	Medium	Manager
Business and Financial Records	Accounting data, supplier invoices, insurance claims	Medium	Medium	Medium	Medium	Manager
System Configuration and Access Logs	Firewall settings, user accounts, audit logs	Medium	High	Medium	Medium	PSO / IT Support
Backup Media (onsite and offsite)	External drives, cloud backups	Very High	High	High	High	Manager
Hardware Assets	Workstations, POS terminals, routers, CCTV	Low	Medium	Medium	Medium	PSO / IT Support
Physical Facilities and Utilities	Pharmacy premises, power supply, UPS	Low	Medium	High	Medium	Manager
Training Materials and SOPs	Staff manuals, awareness guid. 	Low	Low	Medium	Low	PSO

Figure 2. Asset Sensitivity Table for GetWellSoon

Effects of Using the CareConnect Policy

This section covers some of the threats, vulnerabilities, and security breaches that could affect GetWellSoon's information system and stakeholders, as outlined in the CareConnect Security Policy.

Threats

A '**threat**' is a malicious act that seeks to damage or steal data. Cyber threats include computer viruses, data breaches, Denial of Service (DoS) attacks, and other attack vectors (Tunggal, 2025).

Ransomware:

A ransomware attack poses a significant cybersecurity threat to GetWellSoon, given its reliance on electronic patient data and the need for continuous system uptime. Such an attack could encrypt or delete patient prescription data, halt operations, and compromise the TestSafe connection.

While **section 11.1** of CareConnect policy requires daily antivirus updates and virus prevention procedures, GetWellSoon's small size and limited IT resources could increase the risk of delayed patching.

If the pharmacy's backups are not current or properly encrypted (section 6.9), data restoration may be incomplete, potentially breaching **Rule 5** of the Health Information Privacy Code: storage and security of health information.

Insider Negligence or Error:

A human error. Staff accidentally sending patient information to the wrong recipient, sharing login credentials, or failing to log out of a shared terminal are other common threats.

Section 3.4 of the CareConnect policy recognises staff as "custodians of health information" responsible for upholding confidentiality and requires retraining and disciplinary action under **section 5.5**. However, GetWellSoon's busy environment and use of shared workstations increase the likelihood of such mistakes.

Accidental disclosure could damage patient trust, violate the Privacy Act 2020, and trigger a reportable privacy breach under New Zealand law.

Vulnerabilities

A **‘vulnerability’** is a weakness in the system, process, or control that a threat can exploit.

Outdated or Unpatched software:

Section 9.2 of the CareConnect policy requires that vendor-supplied software to be maintained at a supported version and that patches be applied promptly.

In small organisations like GetWellSoon, patch management often depends on external IT contractors, meaning updates may be delayed or incomplete, leaving their critical operation software outdated.

Unpatched software creates exploitable weaknesses for malware or unauthorised access, and this could lead to disruption in the pharmacy operation or patient's health information being stolen.

Weak Password:

Although **section 7.5** of the CareConnect policy outlines strong password standards, smaller pharmacies like GetWellSoon often struggle to enforce them consistently. Staff may use simple or shared passwords for convenience when moving between Point of Sale (POS) and dispensing terminals.

Weak authentication undermines system integrity and exposes sensitive data to external or insider misuse. If a password is compromised, attackers could alter prescriptions, access patient medical history, or issue fraudulent claims, damaging both operational trust and patient safety.

Security Breaches

A **‘security breach’** refers to unauthorised access, disclosure, or manipulation of sensitive data, computer systems, applications, networks, or devices, which leads to risks in data confidentiality, integrity, and availability (“What Are Security Breaches?”, n.d.). This section covers the analysis of the impact and likelihood of two possible security breaches that could happen in GetWellSoon.

Ransomware Infection via Outdated Software:

When ransomware infects the pharmacy workstation via an email attachment, dispensing and TestSafe systems can become encrypted, preventing access to patient data. The impact is **high** because patient services are halted; patient data is inaccessible, and inappropriate decisions in handling this could lead to a violation of the **Health Information Privacy Code 1994** and breaches of **sections 9.2** and **11.1** of the CareConnect Security Policy, which require systems to be patched and anti-malware tools to be updated daily. The likelihood is **medium**, as software updates can be delayed depending on the software vendor's actions. Overall, this breach is **high risk**.

Unauthorised Access Due to Weak Passwords:

This occurs when an ex-employee or attacker logs in using shared credentials, allowing them to view or export patient records. The impact is **high** because confidentiality and integrity of patient records are compromised, and patient trust is lost, which could damage the pharmacy's reputation. The likelihood is **medium to high**, as having a weak password without multi-factor authentication (MFA) is common in small businesses. Overall, this breach is **high risk**.

Security Breach	Impact	Likelihood	Overall Risk Level
Ransomware Infection via Outdated Software	High	Medium	High
Unauthorised Access due to Weak Passwords	High	Medium–High	High

Figure 3. Summary of Impact and Likelihood of Security Breaches

Recommendations

This section covers two recommendations for GetWellSoon to mitigate potential security breaches.

Strengthen Backup and Recovery Controls

Outdated software is vulnerable to ransomware infections that can encrypt or destroy patient and business data. Therefore, it is best practice to back up critical data.

Perform daily encrypted cloud backups and maintain an off-site copy to prevent total data loss during ransomware incidents. Test data restoration monthly as part of the business continuity management **outlined in Section 12** of the CareConnect policy.

This will minimise downtime of operation, prevent permanent data loss, and ensure that GetWellSoon Pharmacy can restore essential services quickly after ransomware attacks.

Enhance Staff Training and Access Control Policies

Weak, shared passwords and staff's lack of security awareness increase the likelihood of unauthorised access to pharmacy systems. So, it is recommended to conduct quarterly training on secure password creation and safe account practices.

Enforce a 90-day password expiry cycle, prohibit shared user accounts, and terminate end-user access immediately when a staff member leaves employment.

This will reduce the risk of credential theft or misuse, ensure staff's accountability for user activity, and enhance overall system confidentiality and integrity.

Conclusion

GetWellSoon requires an appropriate cybersecurity framework to manage potential cybersecurity risks efficiently.

Applying steps in each of the six functions in **NIST CSF 2.0: 'Govern', 'Identify', 'Protect', 'Detect', 'Respond', and 'Recover'** is highly recommended as they align well with CareConnect's security policy. By integrating CareConnect's existing policy with NIST CSF, the pharmacy can ensure data confidentiality, integrity, and availability while meeting NZ Health Network and privacy obligations.

Some effects could affect the pharmacy's information system operations and its stakeholders. Threats include **'Ransomware'** and **'Insider Negligence'**; exploitable vulnerabilities include **'Outdated Software'** and **'Weak Passwords'**. Together, they could cause security risks such as **'Inaccessible encrypted data from ransomware infection'** and **'Unauthorised access to the system'**.

The recommendations for the pharmacy are to **'Strengthen Backup and Recovery Controls'** and **'Enhance Staff Training and Access Control Policies'**.

By applying CareConnect Security Policy, supported by NIST CSF 2.0 controls, GetWellSoon Pharmacy will significantly enhance its cybersecurity. It will protect sensitive patient data, support ongoing regulatory compliance, and foster trust among the pharmacy, its patients, and the broader healthcare network.

References

- Boutin, C. (2023, August 8). *NIST Drafts Major Update to Its Widely Used Cybersecurity Framework*. NIST. Retrieved from <https://www.nist.gov/news-events/news/2023/08/nist-drafts-major-update-its-widely-used-cybersecurity-framework>
- De Felice, G. (2024, September 3). *What is a Risk Matrix, How to prioritize Risks in Project Management*. Gustavo's The Business Automator. Retrieved from <https://www.gustavodefelice.com/p/what-is-a-risk-matrix-how-to-prioritize-severity>
- Kariwala, H. (2025, June 4). *How to Implement NIST CSF: A Step-by-Step Guide to Strengthening Cybersecurity*. Vcomply. Retrieved from <https://www.vcomply.com/blog/implement-nist-csf/>
- Ministry of SaskBuilds and Procurement. (2024, April). *Statement-of-Sensitivity*. Saskatchewan. Retrieved from <https://taskroom.saskatchewan.ca/-/media/project/taskroom/documents/form/statement-of-sensitivity.pdf>
- Raimondo, G., & Locascio, L. (2024, February). *NIST Cybersecurity Framework 2.0: Small Business Quick-Start Guide*. NIST. Retrieved from <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1300.pdf>
- SaltyCloud Research Team. (2025, July 4). *How to Implement NIST CSF 2.0, Complete Guide*. Saltycloud. Retrieved from <https://www.saltycloud.com/blog/how-to-implement-nist-csf/>
- Tunggal, A. (2025, July 2). *What is a Cyber Threat?* UpGuard. Retrieved from <https://www.upguard.com/blog/cyber-threat>
- What Are Security Breaches?* (n.d.). f5. Retrieved from <https://www.f5.com/glossary/security-breaches#:~:text=A%20security%20breach%20refers%20to,applications%2C%20networks%2C%20or%20devices.>
- What is the NIST Cybersecurity Framework?* (n.d.). IBM. Retrieved from <https://www.ibm.com/think/topics/nist>

Appendices

Appendix A

Functions of the NIST CSF framework



Note. This figure illustrates the functions of the NIST CSF framework 2.0. From *NIST Drafts Major Update to Its Widely Used Cybersecurity Framework*, by C. Boutin, 2023, NIST (<https://www.nist.gov/news-events/news/2023/08/nist-drafts-major-update-its-widely-used-cybersecurity-framework>)

Appendix B

Risk Assessment

		Impact →				
		Negligible	Minor	Moderate	Significant	Severe
Likelihood ↑	Very Likely	Low Med	Medium	Med Hi	High	High
	Likely	Low	Low Med	Medium	Med Hi	High
	Possible	Low	Low Med	Medium	Med Hi	Med Hi
	Unlikely	Low	Low Med	Low Med	Medium	Med Hi
	Very Unlikely	Low	Low	Low Med	Medium	Medium

Note. This figure illustrates the methods for assessing prioritised risks. From *What is a Risk Matrix, How to prioritize Risks in Project Management*, by D. Gustavo, 2024, Gustavo's The Business Automator (<https://www.gustavodefelice.com/p/what-is-a-risk-matrix-how-to-prioritize-severity>)